Caso de Prueba: Vulnerabilidad del Flujo de Negocio

OWASP Juice Shop — Selenium + OWASP ZAP + Allure

Repositorio público (código fuente):	https://github.com/oskaracho/zap_v6

Diplomado	UCB — Automatización y Seguridad (V6)
Tester / Autor	oskaracho
Fecha	19/10/2026
Herramientas	Java, Gradle, JUnit 5, Selenium 4, REST Assured, OWASP ZAP, Allure
App objetivo	OWASP Juice Shop

1. Objetivo

Validar la seguridad del **flujo de negocio de compra** de OWASP Juice Shop (registro de usuario -> autenticación -> agregar producto al carrito -> checkout), recorriéndolo con Selenium a través del proxy de OWASP ZAP para capturar todo el tráfico y, a continuación, ejecutar un **active scan** que identifique vulnerabilidades sobre dicho flujo. El resultado se documenta en un reporte Allure con el reporte de alertas de ZAP adjunto.

2. Alcance

App objetivo del caso de prueba: http://demo.owasp-juice.shop/.
URL de referencia del enunciado: https://www.todoist.com/es.

3. Precondiciones

• OWASP ZAP en ejecución con la API habilitada en el puerto **9095** (modo daemon o GUI).
• Google Chrome y chromedriver compatibles instalados.
• JDK y Gradle disponibles (se incluye Gradle Wrapper `./gradlew`).
• Conexión a Internet hacia `demo.owasp-juice.shop`.

4. Especificación del caso de prueba

ID	TC-BIZFLOW-01
Título	Escaneo de vulnerabilidades del flujo de compra (Juice Shop) vía ZAP
Tipo	Seguridad — lógica / flujo de negocio (DAST)
Severidad	Crítica
Datos de prueba	Email dinámico `zapv6_<uuid>@zap.com` · Password `Zapv6!2024`
Pasos	1) Abrir Juice Shop y cerrar banners de cookies/bienvenida. 2) Registrar un usuario nuevo (pregunta de seguridad incluida). 3) Iniciar sesión con el usuario recién creado. 4) Agregar el primer producto al carrito. 5) Ir al carrito y pasar a checkout. 6) Lanzar el active scan de ZAP sobre el host objetivo. 7) Esperar el progreso del escaneo hasta 100%.

Resultado esperado	El flujo completo se ejecuta sin errores; ZAP captura el tráfico, el active scan finaliza al 100% y se genera el reporte de alertas con las vulnerabilidades detectadas, adjunto automáticamente al reporte Allure.
Clase de prueba	`testSuite.JuiceShopBusinessFlowTest`

5. Ejecución satisfactoria en el IDE

• Abrir el proyecto en IntelliJ IDEA (Gradle).
• Levantar OWASP ZAP (API en el puerto 9095).
• Ejecutar la clase `JuiceShopBusinessFlowTest` con click derecho -> *Run*, o por línea de comandos: `./gradlew test`.
• Los resultados Allure se escriben en `build/allure-results`.

6. Reporte Allure

Generar y visualizar el reporte en el navegador:

```
./gradlew test
allure serve build/allure-results
```

El reporte incluye los pasos (*@Step*) del flujo de negocio y, como adjunto, el reporte HTML de alertas de OWASP ZAP (*@Attachment*).

Código fuente completo: https://github.com/oskaracho/zap_v6